PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Configuration sécurisée Stormshield Network Security (SNS)

03-450 ANSSI - Configuration sécurisée d'un pare-feu Stormshield Network Security (SNS) — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'administration doit privilégier des comptes nominatifs et une interface Ethernet dédiée avec des sous-réseaux autorisés.
2. L'antispoofing IP nécessite de déclarer les interfaces internes pour vérifier la légitimité de l'adresse source avant le filtrage.
3. Le blackholing via une route vers la boucle locale permet de détruire les flux destinés à un réseau distant en cas d'erreur de politique IPsec.

Administration du pare-feu

Notion	À retenir
Comptes administrateurs	Utiliser des **comptes nominatifs** (Web/NSRPC). Le **compte local non nominatif** est réservé aux **opérations exceptionnelles**, avec mot de passe fort en coffre-fort.
Authentification et droits	**Annuaire externe** dédié (compte du pare-feu en **lecture seule**) ; droits au **strict nécessaire** via **groupes** de l'annuaire ; modification des droits réservée au compte non nominatif.
Services d'administration	Utiliser une **interface Ethernet dédiée** et un **groupe d'objets** pour les sous-réseaux autorisés.

Configuration réseau et services

Notion	À retenir
Interfaces et antispoofing	Désactiver les **interfaces non utilisées**. Déclarer les **interfaces internes** pour l'antispoofing, utiliser des **routes statiques** pour les réseaux distants et interdire les plages **RFC 5735** venant d'Internet.
Services (Mise à jour, DNS, NTP)	Activer **mises à jour automatiques** (miroir interne ou proxy). Utiliser des **DNS maîtrisés**. Supprimer **objets dynamiques** inutilisés. Activer **NTP** (plusieurs serveurs). Configurer **LDAPS** avec certificat **IGC maîtrisée**.

Politique de filtrage et analyse

Notion	À retenir
Nommage et règles implicites	La politique doit suivre une **convention explicite**. Les **règles implicites** (évaluées avant les manuelles) doivent être **désactivées** après création de règles explicites équivalentes.
Analyse protocolaire et objets	Adapter le niveau (**Firewall**, **IPS** transport ou applicatif) au rôle. Utiliser des **groupes d'objets** pour centraliser les mises à jour lors de changements de topologie.

Certificats, IGC et révocation

Notion	À retenir
IGC	**IGC externe maîtrisée** (RGS) ; à défaut IGC interne pour les équipements **les moins exposés** (secrets supprimés après export, administrateurs dédiés).
Révocation	Vérification des **CRL** imposée pour IPsec, rafraîchissement **automatique** ; import manuel exceptionnel.

Synthèse du VPN IPsec

Notion	À retenir
Profils et authentification	Utiliser **AES-GCM 256**, **SHA 384**, **DH 19**. Privilégier **IKEv2** ou **mode principal** (IKEv1). Authentification par **certificat** préférée à la clé partagée (**entropie ≥ 128 bits**).
Routage, filtrage et NAT	Configurer **blackholing** (route statique boucle locale). Règles de filtrage et NAT **plus spécifiques** que la politique IPsec. Interfaces VPN déclarées **internes** pour l'**antispoofing**.
Tunnels nomades et disponibilité	Mode **Config** pour l'IP rouge. Authentification par **certificat** via **CA intermédiaire**. Activer **Dead-Peer-Detection** (haut, bas ou passif) et **KeepAlive** (flux filtré sans trace).

Supervision, sauvegarde et journalisation

Notion	À retenir
Supervision	**SNMPv3** (AES, SHA1 : acceptable, non conforme RGS), interrogé par les seuls serveurs de supervision.
Sauvegarde	Automatique vers **WebDAV** maîtrisé en HTTPS authentifié, ou export **SSH initié par l'équipement** (jamais l'inverse).
Journalisation	Locale et centralisée, **rotation** automatique, transfert **chiffré** ; a minima filtrage, connexion, VPN IPsec, authentification, administration, statistiques, système, alarmes.

Pièges et confusions

- ⚠ Désactiver les règles implicites de filtrage sans avoir créé de règles explicites équivalentes (risque de perte d'accès).
- ⚠ Désactiver une politique IPsec sans route de blackholing définie (risque d'émission en clair).
- ⚠ Oublier de transférer le fichier backup.na.enc vers un équipement distant (risque d'écrasement automatique).
- ⚠ Utiliser des fonctionnalités non couvertes par la cible de sécurité de qualification sans analyse de risque complémentaire.

Sigles et définitions

SNS — Stormshield Network Security, gamme de pare-feux qualifiée par l'ANSSI.

NSRPC — NetAsq Secure Remote Protocol Client, protocole d'administration en ligne de commande utilisant le port TCP 1300.

Antispoofing IP — Vérification de la légitimité de l'adresse IP source en s'appuyant sur les interfaces internes et la table de routage.

Blackholing — Technique consistant à router des flux vers une adresse fictive de la boucle locale pour les détruire.

UAC — User Access Control, mécanisme de gestion fine des autorisations, du filtrage et du NAT avec un annuaire.

Auto-test

1. Quel port est utilisé par le protocole NSRPC ?
2. Que devient le fichier backup.na.enc lors d'une nouvelle sauvegarde ?
3. Quelle est la méthode de routage pour éviter l'émission en clair en cas d'erreur IPsec ?
4. Quelle est la condition pour qu'une interface soit considérée comme interne pour l'antispoofing ?
5. Que doit-on faire avant de désactiver les règles implicites de filtrage ?

Réponses : **1.** TCP 1300 · **2.** Il est écrasé · **3.** Le blackholing · **4.** Elle est protégée par l'antispoofing et n'accepte que des paquets dont l'adresse source provient de son propre réseau de commutation · **5.** Créer des règles explicites équivalentes

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.